

Nombre: _____

Fecha: _____

TALLER PRÁCTICO DE GESTIÓN DE RIESGOS 2026-2

Caso NovaTech Digital Services S.A.S.

Objetivo

El propósito de este taller es aplicar de manera práctica los conceptos fundamentales de gestión de riesgos. A partir de un caso empresarial, cada grupo deberá identificar y analizar un escenario de riesgo, establecer su nivel de exposición, proponer una respuesta y sustentar sus decisiones ante un comité de riesgos conformado por toda la clase.

Contexto empresarial

NovaTech Digital Services S.A.S. es una empresa colombiana de servicios tecnológicos con sede principal en Bogotá. Cuenta con cerca de 500 empleados y 120 contratistas y presta servicios de desarrollo de software, soporte tecnológico, procesamiento de información y soluciones digitales a empresas de los sectores financiero, salud, comercio y servicios.

Durante los últimos años, NovaTech ha experimentado un crecimiento acelerado. Gran parte de su operación depende actualmente de plataformas digitales y servicios en la nube. La compañía utiliza Microsoft 365 para correo electrónico, colaboración y almacenamiento de documentos, Microsoft Azure para parte de su infraestructura corporativa y AWS para varias aplicaciones desarrolladas para clientes. También utiliza diferentes soluciones SaaS para CRM, recursos humanos, facturación y gestión de proyectos.

La organización administra más de 700 identidades digitales entre empleados, contratistas, administradores y cuentas de servicio. Cerca del 70 % de los empleados trabaja de forma híbrida y accede remotamente a correo electrónico, archivos, aplicaciones empresariales, ambientes de desarrollo y sistemas administrativos. Aunque algunos sistemas críticos utilizan autenticación multifactor, todavía existen aplicaciones cuyo acceso depende únicamente de usuario y contraseña.

NovaTech procesa una cantidad importante de información de clientes, incluyendo datos personales, información contractual, documentos comerciales e información técnica. También almacena información financiera, código fuente, configuraciones de infraestructura, estrategias comerciales y datos de sus empleados.

La continuidad del negocio depende significativamente de la disponibilidad de sus plataformas tecnológicas. Una interrupción prolongada podría afectar la atención de clientes, la facturación, el desarrollo de software, los servicios de soporte y el cumplimiento de acuerdos contractuales. Algunos contratos incluso contemplan penalidades económicas por indisponibilidad.

La compañía trabaja además con aproximadamente 80 proveedores, entre ellos proveedores de nube, empresas de desarrollo, plataformas SaaS, consultores y empresas de soporte tecnológico. Algunos terceros tienen acceso remoto a sistemas corporativos. Sin embargo, las evaluaciones de seguridad sobre proveedores no se realizan actualmente bajo un proceso uniforme.

Durante una reciente revisión interna, la organización identificó varias situaciones que podrían incrementar su exposición: MFA no implementado de manera uniforme, usuarios con privilegios elevados, computadores portátiles utilizados fuera de las instalaciones, dependencia de proveedores externos, aplicaciones con componentes desactualizados, información distribuida en diferentes repositorios y una capacidad limitada del equipo de seguridad frente al crecimiento de la empresa.

Ante esta situación, la dirección de NovaTech decidió realizar una evaluación de riesgos para determinar cuáles escenarios requieren mayor atención y dónde deberían concentrarse los recursos disponibles.

Escenarios de análisis

La clase será dividida en siete grupos. Cada grupo asumirá la responsabilidad de analizar uno de los siguientes escenarios.

Grupo 1 – Compromiso de credenciales

Durante las últimas semanas varios empleados han recibido correos que simulan provenir de Microsoft 365, proveedores e incluso miembros de la dirección. Algunos usuarios ingresaron sus credenciales en páginas fraudulentas. La organización utiliza ampliamente Microsoft 365 y Single Sign-On, pero MFA todavía no está habilitado en todos los sistemas.

El grupo deberá analizar qué podría ocurrir si un atacante obtiene y utiliza las credenciales válidas de un empleado.

Grupo 2 – Ransomware

NovaTech cuenta con cerca de 500 computadores y diferentes servidores corporativos. Aunque dispone de herramientas de protección y mecanismos de respaldo, existen equipos con actualizaciones pendientes, aplicaciones antiguas, información almacenada localmente y usuarios con diferentes niveles de privilegios.

Un incidente de ransomware podría producir pérdida de información e indisponibilidad de servicios críticos para la compañía y sus clientes.

El grupo deberá evaluar el riesgo que este escenario representa para la continuidad de las operaciones.

Grupo 3 – Fuga de información interna

Los empleados y contratistas tienen acceso a información comercial, técnica y de clientes. Algunos usuarios pueden consultar grandes cantidades de información almacenada en SharePoint y otros repositorios corporativos.

Recientemente, un empleado del área comercial anunció que dejará NovaTech para trabajar con un competidor. Actualmente tiene acceso a bases de clientes, precios, propuestas y contratos. La empresa cuenta con acuerdos de confidencialidad, pero el monitoreo sobre el movimiento de información es limitado.

El grupo deberá analizar tanto la posibilidad de una fuga intencional como una exposición accidental de información.

Grupo 4 – Indisponibilidad de un proveedor de nube

Una plataforma utilizada diariamente por aproximadamente 200 empleados se encuentra completamente alojada en un proveedor externo de nube. A través de ella se gestionan solicitudes, actividades operacionales y atención a clientes.

NovaTech cuenta con un acuerdo de disponibilidad con el proveedor, pero no dispone de una plataforma alternativa que pueda activarse inmediatamente ante una falla prolongada.

El grupo deberá analizar cómo la dependencia de este tercero podría afectar la operación y la continuidad del negocio.

Grupo 5 – Vulnerabilidad crítica expuesta a Internet

NovaTech administra una aplicación web utilizada por cerca de 15.000 usuarios externos. La plataforma procesa información de clientes y se integra con diferentes servicios corporativos.

Recientemente fue identificada una vulnerabilidad crítica en uno de sus componentes. Existe una actualización disponible, pero el equipo de desarrollo considera que debe realizar varias pruebas porque la actualización podría afectar la compatibilidad de algunos módulos.

El grupo deberá evaluar el riesgo de mantener temporalmente una vulnerabilidad crítica en una aplicación accesible desde Internet y determinar cómo equilibrar seguridad y disponibilidad.

Grupo 6 – Pérdida de un computador corporativo

Los empleados trabajan frecuentemente desde hogares, hoteles, aeropuertos, oficinas de clientes y espacios de coworking.

Durante el último año se reportaron cuatro computadores corporativos perdidos o robados. Los dispositivos cuentan con herramientas de seguridad y mecanismos de cifrado, aunque no se ha comprobado que todos tengan exactamente la misma configuración.

Los usuarios pueden almacenar temporalmente documentos, archivos de clientes y otra información empresarial en sus equipos.

El grupo deberá analizar las posibles consecuencias de la pérdida o robo de uno de estos dispositivos.

Grupo 7 – Compromiso de un proveedor

Un proveedor externo realiza mantenimiento sobre una plataforma tecnológica de NovaTech. Cinco técnicos cuentan con acceso remoto autorizado a sistemas corporativos.

El proveedor utiliza sus propios computadores y administra internamente sus controles de seguridad. NovaTech no conoce con detalle cómo protege esos dispositivos, administra las cuentas de sus empleados o responde ante incidentes.

El grupo deberá evaluar qué podría ocurrir si un atacante compromete al proveedor y utiliza posteriormente sus accesos legítimos para llegar hasta los sistemas de NovaTech.

Grupo 8 – Exposición de información por configuración incorrecta en la nube

NovaTech utiliza Microsoft Azure, AWS y diferentes servicios SaaS para almacenar información, ejecutar aplicaciones y soportar ambientes de desarrollo.

Durante una revisión técnica se identificó que algunos recursos fueron creados directamente por diferentes equipos y no todos siguen los mismos estándares de configuración. Entre ellos existen repositorios de archivos, servicios de almacenamiento, bases de datos y ambientes de desarrollo que pueden contener información de clientes, documentos corporativos, configuraciones técnicas y datos utilizados para pruebas.

Recientemente, el equipo de seguridad detectó que uno de los repositorios de almacenamiento tenía permisos más amplios de lo esperado. Aunque no se ha confirmado acceso no autorizado, existe la posibilidad de que información sensible haya quedado accesible desde Internet durante varias semanas.

El grupo deberá analizar **qué podría ocurrir si una configuración incorrecta en un servicio de nube expone información sensible de NovaTech o de sus clientes**, considerando las responsabilidades de la organización frente al proveedor de nube.

Objetivo del análisis

Evaluar los riesgos de ciberseguridad que pueden afectar la confidencialidad, integridad y disponibilidad de la información, así como la continuidad, el cumplimiento, las finanzas y la reputación de NovaTech.

Alcance

El ejercicio comprende:

- Empleados, contratistas y proveedores.
- Infraestructura local y servicios en la nube.
- Aplicaciones corporativas y aplicaciones de clientes.
- Identidades digitales y accesos remotos.
- Información personal, comercial, financiera y técnica.
- Procesos críticos de desarrollo, soporte, facturación y atención a clientes.

Horizonte temporal

Se analizará la posibilidad de materialización de los riesgos durante los próximos doce meses.

Escalas de análisis

Valor	Posibilidad de ocurrencia	Consecuencia
1	Baja: no existen antecedentes recientes y las condiciones dificultan el evento.	Menor: afectación limitada, recuperable mediante procedimientos normales.
2	Media: existen condiciones que permiten el evento, aunque su ocurrencia no es continua.	Moderada: interrupción relevante, costos de recuperación o afectación limitada a clientes.
3	Alta: existen antecedentes, intentos frecuentes o condiciones que favorecen claramente el evento.	Grave: interrupción significativa, pérdida de información, incumplimiento, sanciones o daño reputacional.

Nivel de riesgo

Nivel de riesgo = Posibilidad × Consecuencia

Resultado	Nivel	Criterio de actuación
1–2	Bajo	Puede aceptarse con seguimiento periódico.
3–4	Medio	Requiere responsable y acciones planificadas.
6–9	Alto	Requiere tratamiento prioritario y seguimiento directivo